

ระบบต่อต้านการบุกรุกช่องโหว่ทางซอฟต์แวร์
ANTI-EXPLOIT CODE SYSTEM

นาย กิจชัย รั้งสินต์ไพบูลย์
นาย ดนวัต กันท์สุข

ปริญญานิพนธ์นี้เป็นส่วนหนึ่งของการศึกษาตามหลักสูตรปริญญาวิศวกรรมศาสตรบัณฑิต
สาขาวิชาวิศวกรรมคอมพิวเตอร์
คณะวิศวกรรมศาสตร์
สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง
พ.ศ.2548

ระบบต่อต้านการบุกรุกช่องโหว่ทางซอฟต์แวร์
ANTI-EXPLOIT CODE SYSTEM

โดย
นาย กิจชัย รังสิมันต์ไพบูลย์
นาย คนวัต กัณฑ์สุข

อาจารย์ที่ปรึกษา
อาจารย์ อัครเดช วัชรภูพงษ์
ผู้ช่วยศาสตราจารย์ ธนา หงษ์สุวรรณ
อาจารย์ ธนัญชัย ตรีภาค

ปริญญานิพนธ์นี้เป็นส่วนหนึ่งของการศึกษาตามหลักสูตรปริญญาวิศวกรรมศาสตรบัณฑิต
สาขาวิชาวิศวกรรมคอมพิวเตอร์
คณะวิศวกรรมศาสตร์
สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง
พ.ศ.2548

ปริญญานิพนธ์ปีการศึกษา 2548

ภาควิชา วิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์ สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

เรื่อง ระบบต่อต้านการบุกรุกช่องโหว่ทางซอฟต์แวร์

ANTI-EXPLOIT CODE SYSTEM

ผู้จัดทำ

1. นาย กิจชัย รังสิมันต์ไพบูลย์ รหัสประจำตัว 45010044
2. นาย คนวัด กัณฑ์สุข รหัสประจำตัว 45010260

(อาจารย์ อัครเดช วัชรระภูพงษ์)

(ผู้ช่วยศาสตราจารย์ ธนา หงษ์สุวรรณ)

(อาจารย์ ธนัญชัย ศรีภาค)

ระบบต่อต้านการบุกรุกช่องโหว่ทางซอฟต์แวร์

นาย กิจชัย รังสิมันต์ไพบูลย์	45010044
นาย คนวัด กันต์สุข	45010260
อาจารย์ อัครเดช วัชรภูพงษ์	อาจารย์ที่ปรึกษาอาจารย์
ผศ. ธนา หงษ์สุวรรณ	อาจารย์ที่ปรึกษาร่วม
อาจารย์ ธนัญชัย ศรีภาค	อาจารย์ที่ปรึกษาร่วม
ปีการศึกษา 2548	

บทคัดย่อ

เนื่องจากการเกิดบัฟเฟอร์โอเวอร์โฟลล์ จะเกิดขึ้นเมื่อ ผู้ใช้หรือโปรแกรมพยายามบรรจุอินพุตข้อมูลเข้าไปในบัฟเฟอร์ มากเกินกว่าที่ขนาดของบัฟเฟอร์ได้ถูกจัดสรรไว้ ทำให้อินพุตข้อมูลเกิดการล้นหรือ โอเวอร์โฟลล์ขึ้น พฤติกรรมนี้มักเกี่ยวข้องกับฟังก์ชันในภาษา C ตัวอย่างเช่น strcpy() , strcat() และ sprintf() เป็นต้น อย่างไรก็ตาม พฤติกรรมนี้สามารถถูกนำมาใช้เพื่อลักลอบเจาะไปที่ระบบเป้าหมายได้ และด้วยเหตุผลนี้โปรแกรมต่างๆที่เขียนขึ้นมาโดยปราศจากการคำนึงถึงเรื่องความปลอดภัยที่จะส่งผลร้ายตามมาต่อทั้งโปรแกรมของตนเอง และระบบปฏิบัติการที่ใช้จึงเกิดขึ้นได้เสมอ

วิทยานิพนธ์ฉบับนี้ ศึกษาวิธีการเขียนโปรแกรมที่ดี เพื่อไม่ให้ก่อให้เกิดเหตุการณ์เหล่านั้นได้ โดยขั้นตอนการศึกษานั้นเราต้องศึกษาตั้งแต่การโจมตี เพื่อเรียนรู้จุดอ่อนของระบบเพื่อที่จะเจาะเข้าไปได้ และเมื่อทราบถึงกระบวนการบุกรุกแล้ว ก็เป็นขั้นตอนการป้องกันเพื่อไม่ให้ก่อให้เกิดเหตุการณ์นั้นได้อีกได้ในอนาคต โดยระบบปฏิบัติการที่ใช้ในการศึกษาคือ Fedora Core

นอกจากนั้นการศึกษาเรื่องของภัย และการป้องกันภัยจากอินเทอร์เน็ตซึ่งเกิดจากการโปรแกรมโดยไม่คำนึงถึงความปลอดภัยของโปรแกรมก็เป็นเรื่องสำคัญอีกเรื่องหนึ่งเพราะ ภัยที่มาจากอินเทอร์เน็ตนั้น ก่อให้เกิดผลกระทบที่ร้ายแรงมากใน เพราะฉะนั้นจึงควรศึกษาและหาแนวทางป้องกันภัยต่างๆให้เกิดขึ้นน้อยที่สุดเท่าที่จะเป็นไปได้ในอนาคต

ANTI-EXPLOIT CODE SYSTEM

Mr. Kitchai Rangsimunpibul

Mr. Donnawat Kunsuk

Mr. Akkradach Watcharapupong Advisor

Mr. Thana Hongsuwan Co-Advisor

Mr. Thananchai Treepak Co-Advisor

Academic Year 2005

ABSTRACT

Buffer overflow will occurred when user or process try to put data to the buffer more than the size of the buffer that they allocated. Many situations like this always occurred from function in C language for instances `sprintf()`, `strcpy()`, `strcat()` etc. All of this function may be the cause to attack from hacker. For this reason some programs that programmer not concerns for security in his program will make some damage to his program either his operating system

This thesis concerns with the study of how to programming secure program to prevent the attack from hacker. First section of this thesis will explain how to attack and situation that be the cause to attack from attacker and then study how to prevent from all situation. This thesis will use Linux Fedora core to study all of them

Furthermore the attacks in the internet that occurred from insecure programming are important too so this thesis will study about how to attack and prevent attack in internet for prevent damage that will occur as less as it can.

กิตติกรรมประกาศ

การทำปฏิญานิพนธ์ฉบับนี้คณะผู้จัดทำขอขอบพระคุณบิดา มารดา อันเป็นที่เคารพรัก ที่ช่วยอบรมสั่งสอนเลี้ยงดูคณะผู้จัดทำมาเป็นอย่างดี รวมถึงกำลังใจในการทำงานที่คอยให้โดยมาตลอด และส่งเสริมด้านการศึกษาให้คณะผู้จัดทำได้เป็นบุคคลที่มีความรู้มาถึง ณ ปัจจุบันนี้

โครงการนี้คงจะเสร็จสมบูรณ์ได้ หากขาดอาจารย์ที่ปรึกษาทั้งสามท่านคือ อาจารย์ อัครเดช วัชรภูพงษ์ อาจารย์ธนา หงษ์-สุวรรณ และ อาจารย์ธัญชัย ตรีภาค ที่คอยให้คำปรึกษาและคำแนะนำต่างๆเกี่ยวกับโครงการนี้มาโดยตลอด

ขอขอบคุณคณาจารย์และนักศึกษาภาควิชาวิศวกรรมคอมพิวเตอร์ทุกคน ที่คอยให้คำแนะนำในสิ่งดี ๆ ประกอบขึ้นมาเป็นโครงการชิ้นนี้ได้สำเร็จ

นาย กิจชัย รังสิมันต์ไพบูลย์

นาย คนวัต กันท์สุข

สารบัญ

หน้า

บทคัดย่อภาษาไทย.....	I
บทคัดย่อภาษาอังกฤษ.....	II
กิตติกรรมประกาศ.....	III
สารบัญ.....	IV
สารบัญตาราง.....	VII
สารบัญรูป.....	VIII
บทที่ 1 บทนำ.....	1
1.1 ความสำคัญและที่มา.....	1
1.2 วัตถุประสงค์ของปริญญานิพนธ์.....	1
1.3 ขอบเขตของปริญญานิพนธ์.....	2
1.4 วิธีการดำเนินการ.....	2
1.5 ประโยชน์ที่คาดว่าจะได้รับ.....	3
บทที่ 2 Buffer Overflow.....	4
2.1 การจัดการหน่วยความจำ.....	4
2.2 Buffer และส่วนที่เสี่ยงต่อการถูกโจมตี.....	6
2.3 การล้นของ Buffer (Buffer Overflow)	8
2.4 การล้นของ Stack (Stack Overflow)	9
2.5 การล้นของ Heap (Heap Overflow)	12
บทที่ 3 การป้องกันการเกิด Buffer Overflow.....	15
3.1 Static Code Analysis.....	15
3.2 ฟังก์ชันที่เสี่ยงต่อการโจมตีด้วยวิธี buffer overflow.....	21
3.3 Lancelot Scan.....	22
3.4 Lancelot Guard.....	22
3.5 Intrusion-detection software.....	23
บทที่ 4 ภัย และการป้องกันภัยจากอินเทอร์เน็ต.....	25
4.1 SQL Injection.....	25
4.1.1 Numeric SQL Injection.....	25

สารบัญ(ต่อ)

หน้า

4.1.2 การป้องกัน Numeric SQL Injection.....	26
4.1.3 String SQL Injection.....	26
4.1.4 การป้องกัน String SQL Injection.....	26
4.1.5 Blind SQL Injection	27
4.1.6 การป้องกัน Blind SQL Injection.....	27
4.1.7 ตัวอย่างเว็บไซต์ที่สามารถทำ SQL Injection ได้	28
4.2 Javascript injection.....	30
4.2.1 Injection Basics.....	30
4.2.2 Cookie Editing.....	30
4.2.3 Form Editing.....	31
4.2.4 การป้องกันการเกิด Javascript Injection	32
4.3 Cross-Site Scripting (XSS)	32
4.3.1 วิธีการป้องกันช่องโหว่ Cross-Site Scripting (XSS)	33
4.3.2 ตัวอย่างเว็บไซต์ที่สามารถทำ XSS ได้.....	35
4.4 การเข้าแย่งเพื่อครอบครองเซสชัน (Session Hijacking)	41
4.4.1 การจัดการกับ Session.....	42
4.4.2 การเกิด Session Hijacking.....	42
4.4.3 ขั้นตอนการเข้าแย่งเพื่อครอบครองเซสชัน (Session Hijacking)	43
4.4.4 การป้องกันการเข้าแย่งเพื่อครอบครองเซสชัน (Session Hijacking)	44
4.4.5 ตัวอย่างการเข้าแย่งเพื่อครอบครองเซสชัน (Session Hijacking)	47
4.5 ฟังก์ชันที่ควรใช้ในการเขียนโปรแกรมเพื่อเพิ่มความปลอดภัยต่อการถูก รุกราน	51
บทที่ 5 การทดลองและผลการทดลอง.....	55
5.1 ความต้องการของระบบสำหรับโปรแกรม Lancelot Guard และ Lancelot Scan.....	55
5.2 ระบบที่ใช้ทดสอบสำหรับโปรแกรม Lancelot Guard และ Lancelot Scan.....	55
5.3 การทดสอบโปรแกรม Lancelot Scan.....	55

5.4 การทดสอบโปรแกรม Lancelot Guard.....	57
---	----

สารบัญ(ต่อ)

หน้า

5.5 ความต้องการของระบบที่สามารถจำลองสถานการณ์สมมติการบุกรุกเว็บไซต์.....	58
5.6 ระบบที่ใช้ทดสอบการจำลองสถานการณ์สมมติการบุกรุกเว็บไซต์.....	58
5.7 การทดสอบสถานการณ์สมมติการบุกรุกเว็บไซต์	59
 บทที่ 6 วิจัยและสรุป.....	70
6.1 บทสรุป.....	70
6.2 วิจัยสิ่งที่ได้จากโครงงาน	70
6.3 ปัญหาอุปสรรคและแนวทางในการแก้ไข	70
6.4 แนวทางการพัฒนาต่อ	71
 บรรณานุกรม	72
 ภาคผนวก.....	73
ภาคผนวก ก. ตัวอย่างสถานการณ์สมมติภัยบนเว็บไซต์.....	74
ภาคผนวก ข. วิธีปิดการทำงานของ Script บน Microsoft Internet Explorer และ Mozilla Firefox	79

สารบัญตาราง

ตารางที่	หน้า
4.1 ตัวอย่างโค้ดการทำ Escape โดย Javascript	33
4.2 ตัวอย่างโค้ดการทำ Escape โดย PHP.....	34
4.3 ตัวอย่างโค้ดการอนุญาตเฉพาะ Tag ที่กำหนดในการแสดงผล และกรอก Script ออกจาก HTML Code.....	34
4.4 แสดงตัวอย่างการใช้งาน Session	42
4.5 แสดงตัวอย่างการใช้งาน Session	42
4.6 แสดงตัวอย่าง Code ที่มีการใช้งาน User-Agent ในการตรวจสอบ Sesssion	46
4.7 แสดงตัวอย่าง Code ที่มีการใช้งาน User-Agent และ Option อื่น ๆ ในการตรวจสอบ Sesssion	46
4.8 แสดงตัวอย่าง Code ที่มีการใช้งาน Token ในการตรวจสอบ Sesssion	47

สารบัญรูป

รูปที่	หน้า
2.1 ส่วนต่างๆของ memory	5
2.2 แสดง buffer ใน memory	7
2.3 แสดงการเกิด buffer overflow	8
2.4 แสดงวิธีการโจมตีแบบ stack overflow	11
3.1 โฟลว์ชาร์ตของโปรแกรม Lancelot Scan	20
3.2 โฟลว์ชาร์ตของโปรแกรม Lancelot Guard	21
3.3 รูปแสดงการป้องกัน Executeable space	23
3.4 รูปแสดงกรสุ่มตำแหน่งพื้นที่ของ address	23
4.1 หน้า Login ของเว็บไซต์	29
4.2 หน้าในส่วนของการสมาชิกเมื่อ Login ได้สำเร็จ	29
4.3 หน้า Webboard ของเว็บไซต์	36
4.4 หน้าต่างป๊อปอัพแสดง Cookie เมื่อทำ Javascript Injection	36
4.5 หน้าต่าง login ของเว็บไซต์	36
4.6 หน้าต่างป๊อปอัพแสดง Cookie เมื่อทำ Javascript Injection ซึ่งแสดงค่า Session, Username, Password	37
4.7 เมนูของผู้ที่มีสิทธิเป็นสมาชิก	37
4.8 หน้าแก้ไข Profile	37
4.9 หน้า Mailbox ของสมาชิก	38
4.10 หน้าแสดงข้อความใน Mailbox	38
4.11 ฟอรัมโพสต์ข้อมูลลง Webboard	39
4.12 หน้าต่างป๊อปอัพแสดง Cookie เมื่อทำ Javascript Injection	39
4.13 หน้าแสดงข้อมูลที่ได้จากการทำ Cross-Site Scripting	40
4.14 หน้า Mailbox ของสมาชิก	40
4.15 หน้าแสดงข้อความใน Mailbox	41
4.16 รูปแสดงการเกิด Session Hijacking	43
4.17 ทำ Javascript Injection เพื่อสำรวจค่า cookuser และ PHPSESSID ของเครื่องที่ 1	48
4.18 ทำ Javascript Injection เพื่อสำรวจค่า cookuser และ PHPSESSID ของเครื่องที่ 2	48

4.19 Login เข้าสู่ระบบบนเครื่องที่ 1	48
4.20 Login สำเร็จบนเครื่องที่ 1	48
4.21 ภาพแสดงการดักจับ Header ของเครื่องที่ 1	49
4.22 ภาพแสดงการดักจับ Header ของเครื่องที่ 2	49
4.23 ภาพแสดงการดักจับ Header ของเครื่องที่ 1	50
4.24 ภาพแสดงการดักจับ Header ของเครื่องที่ 2	50
4.25 สถานะการเป็นสมาชิกบนเครื่องที่ 1	50
4.26 สถานะการเป็นสมาชิกบนเครื่องที่ 2	51
5.1 test.c	55
5.2 ผลที่ได้จากการตรวจสอบการใช้ฟังก์ชันที่เสี่ยงต่อการถูกโจมตีของ test.c	56
5.3 ผลที่ได้จากการตรวจสอบการให้ค่าเกินขอบเขตของตัวแปรใน test.c	57
5.4 ผลที่ได้จากการทำ stack overflow	57
5.5 ผลที่ได้จากการทำ stack overflow โดยกันด้วย lancelet guard	58
5.6 ข้อความใน /var/log/secure	58
5.7 หน้าแรกของเว็บไซต์	59
5.8 เลือกรูปแบบการบุกรุก	59
5.9 การทำ Numeric SQL Injection	60
5.10 วิธีการป้องกัน Numeric SQL Injection	60
5.11 ตัวอย่างผลจากการป้องกันการเกิด Numeric SQL Injection	61
5.12 Javascript Injection	61
5.13 ตัวอย่างสถานการณ์สมมติการบุกรุกแบบ Javascript Injection	62
5.14 รูปแสดงราคาก่อนทำ Javascript Injection	63
5.15 รูปแสดงราคาหลังทำ Javascript Injection	63
5.16 การป้องกันการเกิด Javascript Injection	64
5.17 Cross-Site Scripting	64
5.18 บอร์ดสำหรับลองทำ Cross-Site Scripting	65
5.19 วิธีการป้องกันช่องโหว่ Cross-Site Scripting	66
5.20 วิธีการป้องกันช่องโหว่ Cross-Site Scripting โดยการทำให้ Escape	67
5.21 วิธีการป้องกันช่องโหว่ Cross-Site Scripting โดยการทำให้ Tag Filter	67
5.22 การเกิด Session Hijacking	69